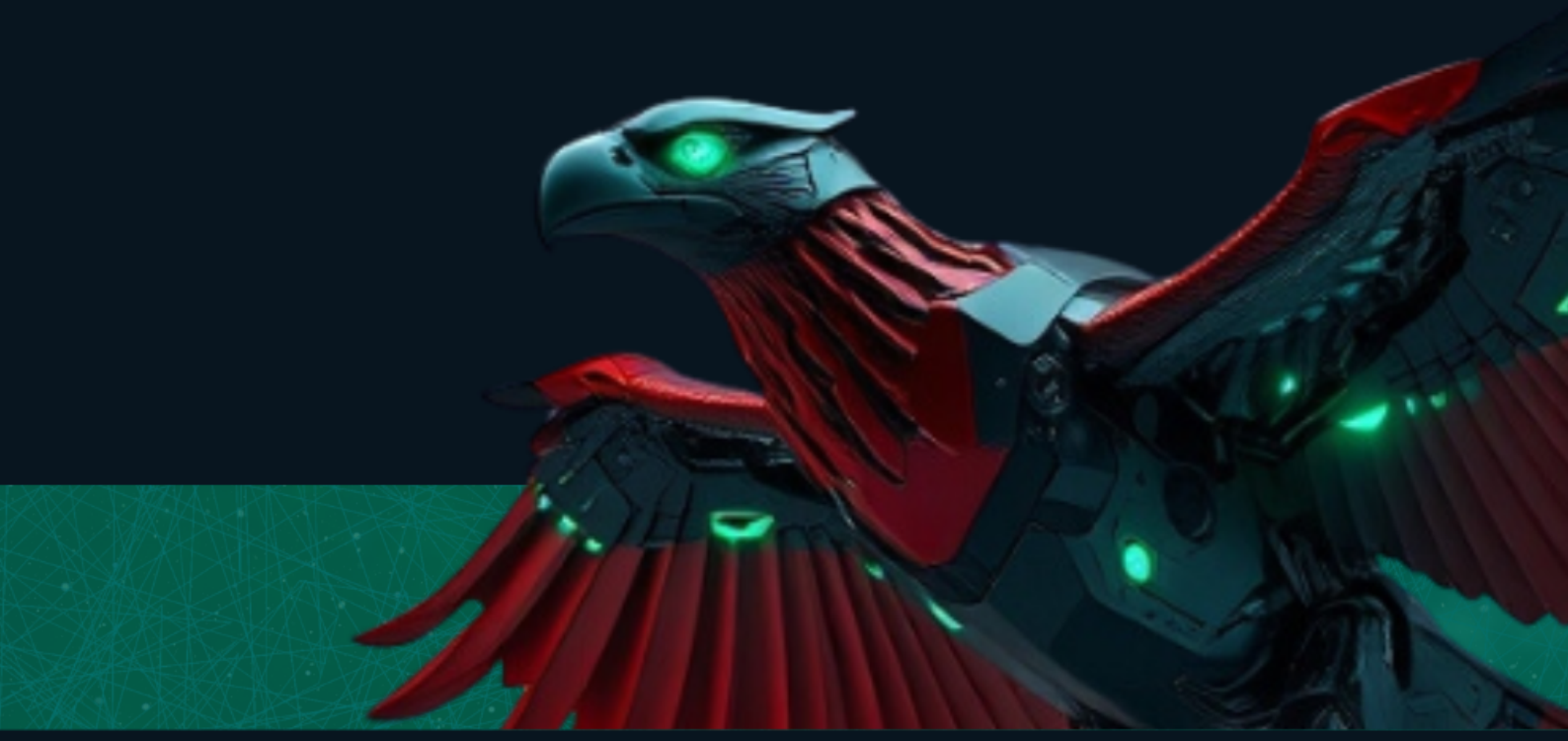
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Hunt | Hollow Panda
Sub Title	Hollow Panda is a sophisticated, nation-state cyber espionage group operating out of China.
Status	Closed
Type	Alert
Severity	—
Source	US News
Created At	Jun 03, 2026, 12:38 AM

Threat Hunt | Hollow Panda

Hollow Panda is a sophisticated, nation-state cyber espionage group operating out of China.

Type: ALERT • Source: US News • Created At: Jun 03, 2026, 12:38 AM

Analysis Summary

On June 2nd at 11:30 PM, Cythority's vSOC conducted a threat hunt focused on Hollow Panda covering activity within the past 30 days. Hollow Panda is a sophisticated, nation-state cyber espionage group operating out of China. First tracked by threat intelligence firms like CrowdStrike around January 2023, this advanced persistent threat (APT) actor primarily focuses on long-term intelligence gathering and strategic data exfiltration rather than immediate financial gain or disruptive attacks. The group maintains a broad global footprint, aggressively targeting organizations across Southeast Asia, South Asia, Oceania, the Middle East, South America, and North America.

In terms of tradecraft, Hollow Panda relies heavily on exploiting perimeter network infrastructure to bypass traditional endpoint security controls. Their signature initial access vector consistently involves targeting and exploiting vulnerabilities in edge devices, specifically Check Point VPN appliances, to quietly establish a foothold within a victim's internal network. Once inside, they typically deploy ShadowPad, a modular and highly capable remote access trojan (RAT) frequently shared among distinct Chinese espionage groups, to maintain persistent access and move laterally.

The threat actor casts a wide net across key economic, technological, and critical infrastructure sectors. Notably, recent threat intelligence, such as the CrowdStrike 2026 Financial Services Threat Landscape Report, highlights Hollow Panda's active role in executing stealthy hands-on-keyboard intrusions against financial institutions in countries like the Philippines, Indonesia, and Brazil, likely to gain economic intelligence and map regional financial systems.

During this hunt, a total of 20 Indicators of Compromise (IOCs) were identified, including domains, URLs, IP addresses, email addresses, filenames, and file hash values. These indicators were aggregated from

CrowdStrike, internal telemetry, and additional intelligence sources referenced in this report. All identified IOCs were enriched using OSINT and threat intelligence platforms to validate their reputation. Analysis confirmed that the indicators are associated with malicious activity.

A CQL Advanced Event Search was conducted across the environment to identify any evidence of activity related to these indicators. No matches or suspicious activity were observed, confirming no current or historical presence within the environment. As a preventative measure, the validated malicious IOCs have been added to the IOC Management Block List to mitigate potential future exposure. This proactive control strengthens the security posture and reduces the attack surface.

Based on the investigation and analysis performed, no impact to the environment has been identified and no further action is required at this time.

Targeted Industries:

Pharmaceutical, Government Technology, Retail, Academic, Consulting and Professional Services, Biomedical, NGO, Manufacturing, Logistics, Financial Services, Agriculture, Healthcare, Energy, Aerospace, Chemicals

Targeted Countries:

Canada, Hong Kong, Malaysia, Turkey, Italy, South Africa, Hungary, Ireland, Chile, Indonesia, Taiwan, Greece, United States, Mexico, Suriname, Kenya, Bulgaria, Germany, Australia, Thailand, Israel, France, Ecuador, Angola, Brazil, Guatemala, Philippines, Ukraine, India, South Korea

Community Identifiers:

N/A

Affected Product

- perimeter network infrastructure

Impact

- T1190 – Exploitation of Public-Facing Application
- T1203 – Exploitation for Client Execution
- T1059 – Command and Scripting Interpreter
- T1543.003 – Create or Modify System Process
- T1574.002 – Hijack Execution Flow
- T1070 – Indicator Removal on Host
- T1140 – Deobfuscation/Decoding of Files or Information
- T1027 – Obfuscated Files or Information
- T1016 – System Network Configuration Discovery
- T1082 – System Information Discovery

Indicators of Compromise (IOCs)

IP

- 177[.]136.225[.]191
- 192[.]144[.]23[.]37
- 89[.]38[.]225[.]202
- 159[.]89[.]201[.]73
- 86[.]106[.]85[.]51
- 31[.]192[.]107[.]157
- 208[.]85[.]16[.]252
- 37[.]120[.]239[.]33
- 139[.]84[.]137[.]63

DOMAIN

- Axb1[.]com
- App[.]axb1[.]com
- dns[.]reasonsbatesystem[.]xyz

- reasonsbatesystem[.]xyz
- app[.]reasonsbatesystem[.]xyz
- kzb[.]superdasqe[.]me
- updata[.]chtq[.]net
- system[.]chtq[.]net
- free[.]threat7858[.]info
- updata[.]dsqurey[.]com
- dscriy[.]chtq[.]net

Remediation

• Prioritize immediate deployment of vendor-supplied hotfixes for internet-facing security appliances.

• Turn off the Mobile Access or Remote Access VPN blades on appliances if they are not strictly required for business operations to reduce the device's attack surface.

• Hollow Panda exploits network devices to harvest credentials. Routinely audit edge gateways to remove legacy local accounts, enforce robust password complexity, and require phishing-resistant multi-factor authentication (MFA) for all administrative access.

• Ensure management interfaces (SSH, WebUI) are never exposed directly to the public internet.

• ShadowPad heavily relies on DLL search order hijacking (placing a malicious DLL alongside a legitimate, trusted executable). Configure Endpoint Detection and Response (EDR) tooling to flag or block unsigned or anomalous DLLs loading from non-standard directories

• Once ShadowPad initializes, it frequently obfuscates its core payload and hides it inside the Windows Registry. Implement proactive threat hunting queries to detect anomalous or highly encrypted binary data blobs stored within unexpected CLSID keys.

• Keep host-based endpoint protection agents in enforcement/blocking mode.

• Isolate edge appliances from the internal corporate network. Perimeter devices should exist in a strictly firewalled Demilitarized Zone (DMZ).

• Restrict and audit the usage of native administrative tools like PowerShell, Windows Management Instrumentation (WMI), and PsExec. Hollow Panda relies on these built-in utilities for internal system discovery and network mapping.

• ShadowPad uses standard web protocols (HTTP/HTTPS) for command-and-control communication to blend in with normal web traffic. Implement SSL/TLS decryption on perimeter firewalls to inspect outbound traffic for unusual user-agents, unauthorized symmetric/asymmetric encryption layers, or beaconing behavior to unlisted or newly registered external IPs.